

Materi Pembelajaran Bitcoin #1

Bitcoin Self-Custody & Cold Wallet (Air-Gapped)

Fondasi Keamanan Menyimpan Bitcoin Sendiri

by Paskah Bire | kapazz09.github.io

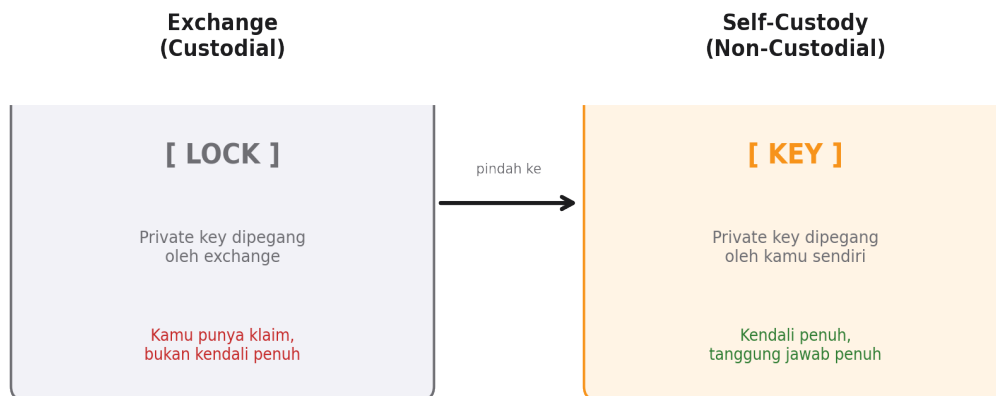
Daftar Isi

1. Kenapa Self-Custody Itu Penting
2. Hot Wallet vs Cold Wallet (dengan Contoh Aplikasi & Merek)
3. Kenapa Air-Gapped Adalah Level Tertinggi Cold Storage
4. Tingkatan Keamanan Berdasarkan Cara Koneksi
5. Seed Phrase & BIP39 (Termasuk Passphrase)
6. Metal Backup & Prinsip 3 Lokasi Terpisah
7. Recovery Test
8. Legacy: Rencana Warisan untuk Keluarga
9. Kesalahan Umum Pemula

Kenapa Self-Custody Itu Penting

"Not your keys, not your coins." Bitcoin yang disimpan di exchange (Indodax, Tokocrypto, dll) secara teknis bukan sepenuhnya milikmu — kamu punya **klaim** atas Bitcoin, tapi exchange yang pegang kuncinya. Kalau exchange diretas, bangkrut, atau membekukan akunmu, kamu tidak punya kendali.

Self-custody artinya kamu sendiri yang menyimpan private key — kode rahasia yang membuktikan kepemilikan Bitcoin di blockchain. Ini prinsip inti Bitcoin: desentralisasi bukan cuma soal jaringan, tapi soal siapa yang pegang kendali atas asetmu.

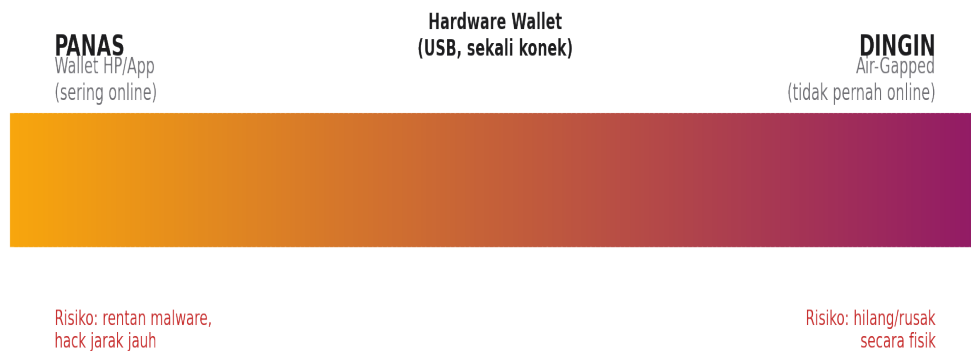


Perbedaan mendasar: siapa yang memegang private key.

Hot Wallet vs Cold Wallet

Hot wallet adalah aplikasi yang terhubung internet (contoh: wallet di HP). Praktis untuk transaksi harian, tapi karena selalu online, rentan terhadap malware, hack, atau serangan jarak jauh.

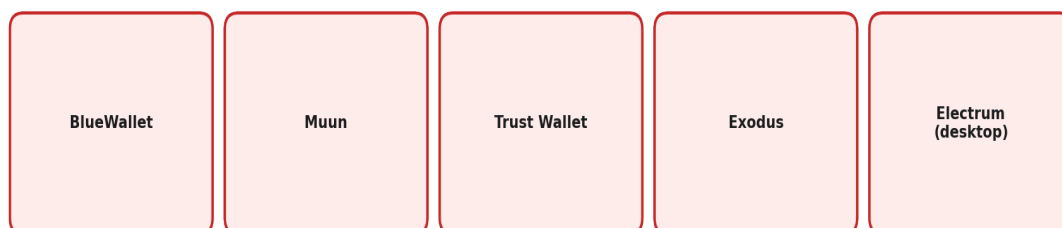
Cold wallet adalah perangkat di mana private key disimpan sepenuhnya offline. Ini standar untuk menyimpan Bitcoin dalam jumlah yang ingin diamankan jangka panjang.



Semakin ke kanan, semakin sulit dijangkau serangan digital — tapi risiko fisik (hilang/rusak) meningkat.

Contoh Aplikasi & Merek di Dunia Nyata

Contoh Aplikasi Hot Wallet (Software, Terhubung Internet)



Praktis untuk transaksi harian & jumlah kecil — tapi private key tersimpan di perangkat yang terhubung internet.

Contoh hot wallet yang umum dipakai — semuanya berjalan di perangkat yang terhubung internet.

Contoh Merek Cold Wallet (Hardware, Offline)



Private key disimpan sepenuhnya offline di perangkat khusus — standar untuk penyimpanan jangka panjang.

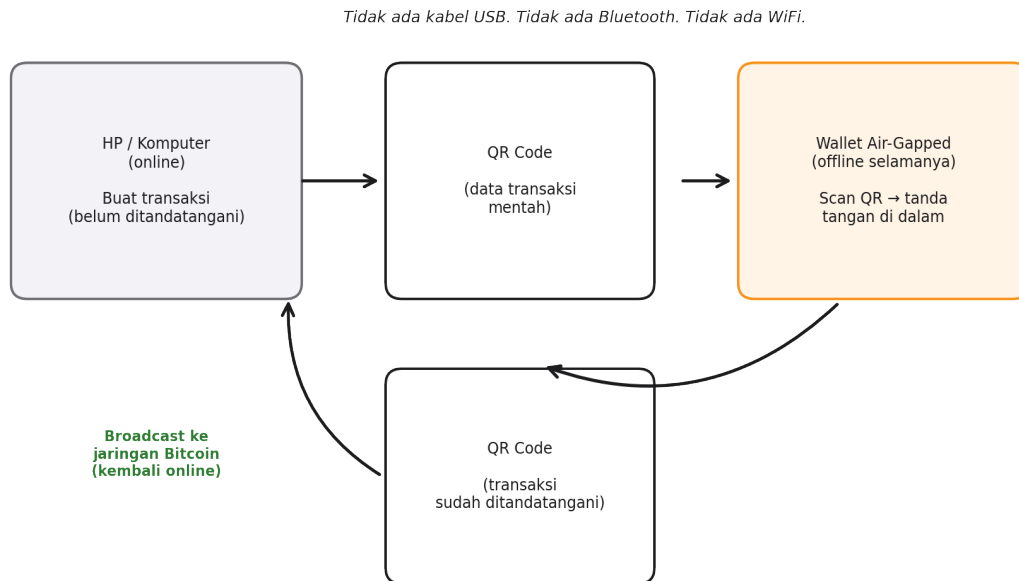
Contoh merek cold wallet yang umum dipakai — semua menyimpan private key sepenuhnya offline.

Catatan penting: tidak semua cold wallet dari merek yang sama punya metode koneksi yang sama. Misalnya, sebagian model dalam satu merek terhubung lewat USB, sebagian lagi lewat Bluetooth, dan sebagian lainnya sepenuhnya air-gapped. Perbedaan ini yang paling menentukan tingkat keamanan, dibahas di bagian berikutnya.

Kenapa Air-Gapped Adalah Level Tertinggi Cold Storage

Tidak semua cold wallet setara. Hardware wallet yang tetap konek USB ke komputer saat transaksi memang offline saat menyimpan, tapi tetap ada momen "kontak" dengan perangkat yang terhubung internet.

Air-gapped wallet adalah perangkat yang secara fisik tidak pernah punya jalur komunikasi digital ke internet. Transaksi ditandatangani secara offline, lalu data dipindahkan lewat **QR code** yang dipindai kamera — bukan kabel data, bukan Bluetooth, bukan WiFi.



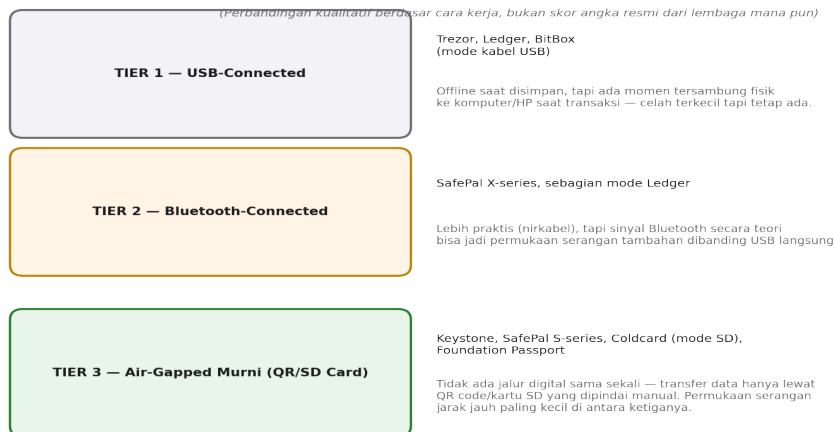
Alur signing air-gapped: satu arah lewat QR code, tidak ada jalur digital yang bisa disusupi dari jarak jauh.

Karena tidak ada jalur transfer data digital yang aktif, malware tidak punya cara "menjangkau" private key di dalam perangkat. Penyerang harus punya akses fisik langsung ke perangkatnya — jauh lebih sulit dan berisiko bagi mereka.

Tingkatan Keamanan Berdasarkan Cara Koneksi

Berikut perbandingan kualitatif berdasarkan cara kerja masing-masing metode koneksi — ini bukan skor resmi dari lembaga audit manapun, melainkan pemahaman logis dari berapa banyak "jalur digital" yang aktif pada tiap jenis perangkat.

Tingkatan Keamanan Cold Wallet Berdasarkan Metode Konektivitas



Semakin sedikit jalur komunikasi digital aktif, semakin kecil celah untuk serangan jarak jauh — keamanan akhir tetap bergantung juga pada kebiasaan pengguna (backup, recovery test, dll).

Semakin sedikit jalur komunikasi digital aktif, semakin kecil permukaan serangan jarak jauh.

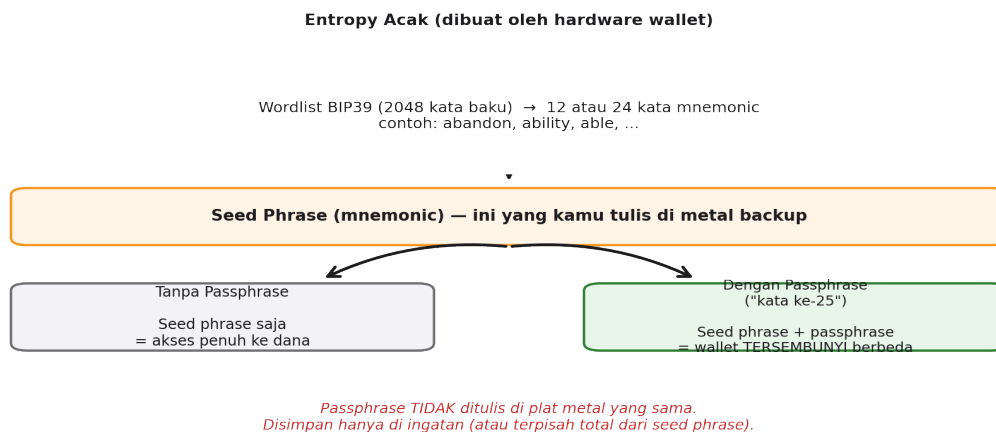
Yang perlu digarisbawahi: perangkat di tier lebih tinggi (USB atau Bluetooth) **bukan berarti tidak aman**. Selama private key tetap tersimpan di secure element (chip khusus tahan ekstraksi) dan tidak pernah keluar dalam bentuk mentah, risikonya tetap jauh lebih rendah dibanding hot wallet. Air-gapped hanya menghilangkan satu kategori risiko tambahan (serangan lewat jalur komunikasi digital), bukan satu-satunya faktor keamanan yang berarti.

Seed Phrase & BIP39: Kunci dari Segala Kunci

Saat setup wallet, kamu diberi **seed phrase** — biasanya 12 atau 24 kata. Ini bukan sekadar kata acak: seed phrase mengikuti standar bernama **BIP39 (Bitcoin Improvement Proposal 39)**, yang menentukan bagaimana kata-kata ini dibuat dan diubah menjadi kunci kriptografis.

Begini alurnya secara teknis:

- Hardware wallet membuat **entropy** — angka acak dengan tingkat keacakan yang sangat tinggi.
- Entropy itu dipetakan ke **wordlist BIP39**, daftar baku berisi 2048 kata bahasa Inggris. Hasilnya adalah 12 atau 24 kata mnemonic yang mudah ditulis dan dibaca manusia, dibanding menulis kode biner mentah.
- Kata-kata ini lalu diproses lagi (lewat fungsi kriptografis) menjadi seed — angka besar yang menjadi induk dari semua private key di wallet-mu.



Dari entropy acak, ke wordlist baku, ke seed phrase — lalu opsional ditambah passphrase.

Passphrase: "Kata ke-25" yang Membuat Perbedaan

Ini yang menurut saya menjadi salah satu faktor pembeda paling penting dibanding self-custody biasa. BIP39 memungkinkan penambahan **passphrase** — sebuah kata atau kalimat tambahan di luar seed phrase standar. Sering disebut "kata ke-25" (untuk seed 24 kata).

- Seed phrase yang sama, dengan passphrase yang berbeda, akan menghasilkan **wallet yang sepenuhnya berbeda** — alamat berbeda, saldo berbeda, seolah-olah wallet terpisah total.
- Tanpa passphrase yang benar, seed phrase saja tidak bisa membuka wallet "tersembunyi" ini — bahkan sistem wallet-nya sendiri tidak bisa membedakan mana passphrase yang benar dan yang salah, ia hanya akan menampilkan wallet kosong yang berbeda.
- Efeknya: kalau seed phrase fisik dicuri atau dipaksa diserahkan, dana sebenarnya tetap aman selama passphrase tidak ikut diketahui.

Konsekuensi penting: passphrase **tidak boleh** ditulis di plat metal yang sama dengan seed phrase — itu menghilangkan seluruh manfaatnya. Idealnya disimpan hanya di ingatan, atau di lokasi yang benar-benar terpisah dari seed phrase fisik.

Cara Membuat Passphrase yang Kuat (Bukan Data Pribadi)

Kesalahan paling umum pemula: menganggap passphrase yang "familiar" berarti aman — lalu memakai nama sendiri, nama pasangan, tanggal lahir, atau nama anak. Ini justru **melemahkan** keamanan, bukan menambah. Data seperti itu ada di KTP, akta lahir, media sosial, bahkan mudah ditelusuri oleh orang yang mengenal kita. Familiar bagi pemilik tidak sama dengan rahasia bagi orang lain.

- **Tidak berhubungan dengan data yang bisa dicari orang lain** tentang dirimu — bukan nama, tanggal, alamat, nomor HP, atau apa pun yang tertaut ke identitas publikmu.
- **Panjang lebih penting daripada rumit.** Kalimat acak yang panjang jauh lebih kuat daripada kata pendek yang "terlihat" rumit tapi mudah ditebak polanya.
- **Logikanya hanya masuk akal bagimu sendiri** — bukan gabungan kata yang related satu sama lain secara jelas, tapi kombinasi yang personal secara struktur berpikir, bukan personal secara data.
- **Bukan kutipan terkenal, lirik lagu, atau frasa populer** — itu termasuk daftar kata yang sudah diantisipasi dalam serangan kamus (dictionary attack).

Cara praktis membuatnya: pilih beberapa kata acak yang tidak berurutan secara makna, lalu satukan dengan cara unik milikmu sendiri — bisa lewat asosiasi pribadi yang tidak tertulis di mana pun, atau lewat metode acak seperti melempar dadu untuk memilih kata dari daftar kata baku (dikenal sebagai metode *diceware*). Yang penting: hasil akhirnya tidak bisa direkonstruksi dari informasi tentang dirimu yang beredar di luar sana.

Disimpan di Kepala Saja: Boleh, dengan Syarat

Karena passphrase memakai kata-kata yang kamu pilih sendiri, menyimpannya hanya di ingatan — tanpa catatan fisik sama sekali — adalah pilihan yang valid dan banyak dipakai. Ini menghilangkan risiko passphrase ditemukan bersama seed phrase.

Tapi ini bukan berarti "otomatis aman". Trade-off yang harus disadari penuh: satu-satunya risiko berpindah dari "dicuri" menjadi "lupa permanen". Kalau passphrase yang hanya ada di kepala terlupa, dana di wallet tersembunyi itu hilang selamanya. Seed phrase yang benar sekalipun tidak akan membantu, karena passphrase yang berbeda menghasilkan wallet yang berbeda pula.

Kalau memilih menyimpan hanya di kepala, disiplinkan diri untuk mengucapkan/mengetiknya ulang secara berkala (misalnya saat recovery test) supaya tidak pudar dari ingatan — jangan hanya dibuat sekali lalu dianggap selesai.

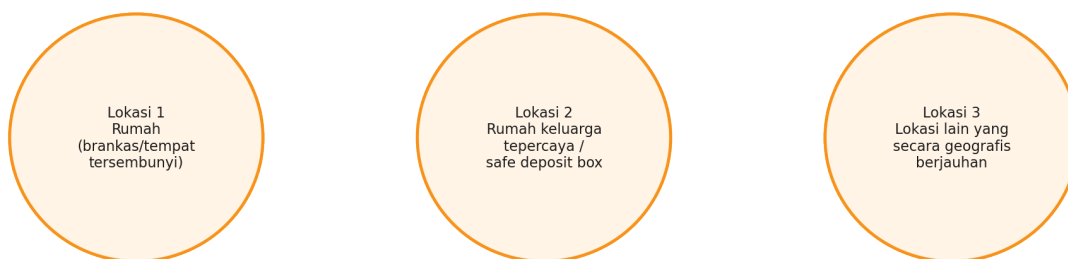
Kenapa Backup Kertas Tidak Cukup: Metal Backup

Kertas rentan kebakaran, banjir, rayap, atau sekadar lapuk dimakan waktu. Solusi yang lebih tahan lama adalah **metal seed backup** — plat logam tahan api dan air tempat seed phrase diukir atau dicetak.

Prinsip 3 Lokasi Terpisah

Satu salinan di satu tempat berarti satu titik kegagalan. Prinsip yang saya pahami dan anggap penting untuk diterapkan: simpan **3 salinan metal backup di 3 lokasi yang secara fisik dan geografis terpisah**.

Prinsip: 3 Salinan Seed, di 3 Lokasi Terpisah



Kenapa terpisah secara geografis? Satu kebakaran, banjir, atau pencurian tidak boleh menghapus lebih dari satu salinan sekaligus.

Tiga salinan, tiga lokasi berbeda — supaya satu kejadian buruk tidak menghapus semua akses.

- **Lokasi 1 — tempat utama:** di rumah, di tempat tersembunyi/brankas yang tidak mudah ditemukan orang lain.
- **Lokasi 2 — pihak/tempat terpercaya kedua:** rumah keluarga terpercaya, atau safe deposit box bank.
- **Lokasi 3 — jarak geografis berbeda:** kota atau wilayah lain, supaya bencana lokal tidak menghapus lebih dari satu salinan sekaligus.

Catatan jujur: semakin banyak lokasi, semakin tahan terhadap kehilangan — tapi juga semakin banyak titik yang berpotensi "bocor" kalau salah satu lokasi tidak dijaga dengan baik. Ini keseimbangan, bukan aturan mutlak yang harus ditambah terus.

Recovery Test: Langkah yang Sering Dilewatkan Pemula

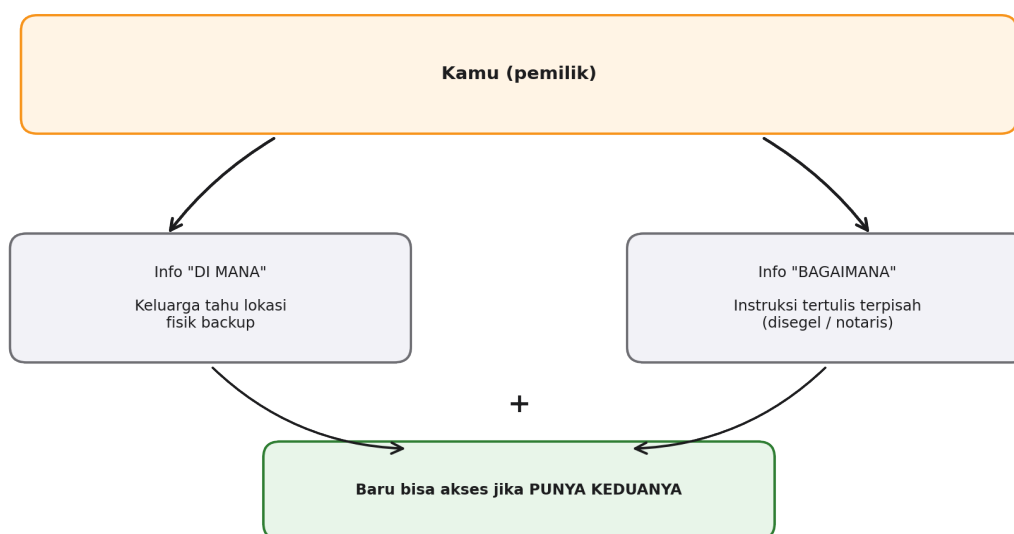
Setup wallet tanpa pernah menguji proses pemulihan itu seperti punya alat pemadam kebakaran tanpa pernah dicek apakah masih berfungsi. **Recovery test** berarti sengaja memulihkan akses wallet (memakai wallet kosong terpisah) hanya menggunakan backup yang disimpan — untuk memastikan backup itu benar, lengkap, dan bisa dibaca.

- Memastikan tidak ada kesalahan urutan atau ejaan kata.
- Memastikan plat metal belum rusak, aus, atau sulit dibaca.
- Melatih diri sendiri agar tidak panik kalau suatu saat benar-benar butuh recovery dalam kondisi darurat.

Legacy: Rencana Warisan untuk Keluarga

Salah satu risiko yang sering diabaikan: kalau terjadi sesuatu pada pemilik wallet, dan tidak ada seorang pun yang tahu di mana atau bagaimana mengakses Bitcoin tersebut, dana itu hilang selamanya.

Tapi memberi tahu keluarga begitu saja juga bukan solusi sederhana. Ada trade-off nyata: semakin banyak orang tahu *di mana* dan *bagaimana* mengakses sekaligus, semakin besar juga risiko pencurian dari dalam. Perlu ada pemisahan.



Pemisahan informasi: satu pihak tahu lokasi, pihak lain (atau dokumen tersegel) menyimpan cara akses.

- **Pisahkan "di mana" dan "bagaimana".** Keluarga inti bisa tahu lokasi fisik backup, tapi instruksi lengkap cara mengakses sebaiknya dituliskan terpisah — misalnya dalam dokumen tersegel yang dititipkan ke notaris.
- **Instruksi tertulis, bukan hanya lisan.** Tulis langkah-langkah dasar dengan bahasa sederhana, tanpa perlu menyertakan seed phrase itu sendiri di dokumen yang sama.
- **Recovery test bersama, secukupnya.** Minimal satu kali, pasangan atau anak diajak memahami dan mencoba proses pemulihan.

Ini bagian yang masih terus saya sempurnakan sendiri — keseimbangan antara "keluarga bisa mengakses kalau perlu" dan "tidak membuka celah keamanan baru" tidak punya jawaban tunggal yang pas untuk semua orang.

Kesalahan Umum Pemula

- Menyimpan seed phrase di foto galeri HP, catatan digital, atau cloud storage.
- Hanya punya satu salinan backup, di satu lokasi.
- Tidak pernah menguji apakah backup benar-benar bisa dipakai untuk recovery.
- Membeli hardware wallet bekas atau dari penjual tidak resmi.
- Menulis passphrase di tempat yang sama dengan seed phrase.

Penutup

Self-custody memberi kendali penuh, tapi kendali itu datang dengan tanggung jawab penuh — tidak ada "lupa password, klik reset" seperti di exchange. Prinsip air-gapped, BIP39 dengan passphrase yang dipahami dengan benar, backup di beberapa lokasi terpisah, recovery test rutin, dan rencana warisan yang jujur adalah pendekatan yang menurut saya paling masuk akal untuk siapa pun yang serius menyimpan Bitcoin jangka panjang.